

Rapport de Due Diligence OSINT

Executive Summary

Dans le cadre d'un scénario pédagogique d'acquisition, une enquête de due diligence OSINT a été menée afin d'évaluer les risques réputationnels, professionnels et cyber associés à la cible étudiée.

Rémi Kinkel a été utilisé comme dirigeant de substitution et La Plateforme comme principale organisation professionnelle liée à la cible.

L'investigation s'est appuyée exclusivement sur des sources publiquement et légalement accessibles : registres officiels, sources institutionnelles, moteurs de recherche, réseaux professionnels publics, données DNS, sources techniques et bases spécialisées de sécurité.

L'analyse a permis de confirmer plusieurs éléments professionnels et de cartographier une partie de l'exposition numérique publique de La Plateforme.

Aucun élément réputationnel ou juridique majeur susceptible de justifier un NO-GO n'a été identifié dans les sources consultées.

Un signal de risque cyber significatif a cependant été relevé : un rapport public Open Bug Bounty concernant students-laplateforme.io décrit un défaut de contrôle d'accès classé CWE-284. L'état actuel de correction de ce signalement n'a pas pu être confirmé depuis les seules sources ouvertes.

D'autres pistes de durcissement ont également été identifiées, notamment une politique DMARC configurée en mode p=none, l'absence d'enregistrement CAA observé et plusieurs dépendances envers des prestataires externes.

Au regard de ces éléments, la recommandation finale est :

GO CONDITIONNEL

La poursuite de l'acquisition est recommandée sous réserve d'un audit technique complémentaire, de la vérification du traitement du signalement cyber identifié et de la mise en œuvre des mesures de durcissement proposées.

1. Contexte et objectifs

1.1 Contexte de la mission

Cette mission s'inscrit dans un exercice pédagogique de due diligence OSINT réalisé dans le cadre d'un scénario fictif d'acquisition d'entreprise.

La société fictive NovaTech Défense constitue le contexte initial de l'étude. Afin de permettre la réalisation concrète de l'enquête à partir de données publiques réelles, Rémi Kinkel s'est porté volontaire comme cible de substitution.

L'objectif n'est donc pas d'enquêter sur une société réelle dans le cadre d'une opération financière réelle, mais de reproduire la démarche méthodologique d'une due diligence appliquée à une cible identifiable et à son environnement professionnel public.

1.2 Cible principale

La cible principale de substitution est Rémi Kinkel.

L'enquête porte uniquement sur les informations publiquement accessibles et pertinentes dans le cadre professionnel de la mission.

La Plateforme a été identifiée comme l'une des principales organisations professionnelles associées à la cible et constitue donc un élément important de l'analyse.

1.3 Organisation de substitution

Dans le scénario pédagogique, l'environnement professionnel public de la cible est utilisé comme support afin d'évaluer les risques pouvant être pertinents dans le cadre d'une acquisition.

L'analyse porte notamment sur :

- l'identité professionnelle publique ;
- les organisations liées ;
- la présence numérique observable ;
- l'infrastructure technique publiquement visible ;
- les dépendances externes ;
- les signaux réputationnels et cyber accessibles depuis des sources ouvertes.

1.4 Objectifs de la due diligence

Les objectifs de l'enquête sont :

- vérifier les principaux éléments professionnels publics associés à la cible ;

- identifier les organisations et actifs numériques pertinents ;
- rechercher d'éventuels signaux de risque réputationnel, juridique ou cyber ;
- cartographier les relations principales observées ;
- évaluer les risques identifiés ;
- proposer des mesures de réduction du risque ;
- formuler une recommandation finale de type GO, NO-GO ou GO CONDITIONNEL.

2. Périmètre et cadre de l'enquête

2.1 Périmètre

Le périmètre de l'enquête comprend :

- Rémi Kinkel en tant que cible principale de substitution ;
- les organisations professionnelles publiquement associées à la cible ;
- La Plateforme en tant qu'organisation principale étudiée ;
- les domaines et actifs numériques publics identifiés ;
- les informations issues de registres officiels ;
- les sources professionnelles et institutionnelles accessibles ;
- les données techniques publiquement consultables ;
- les sources spécialisées de sécurité accessibles sans authentification.

2.2 Limites

L'enquête repose exclusivement sur des informations publiques.

Elle ne permet donc pas d'évaluer directement :

- les systèmes internes ;
- les configurations non exposées publiquement ;
- les politiques internes de sécurité ;
- les contrats ;
- les mécanismes internes de contrôle d'accès ;
- l'état réel de correction d'une vulnérabilité ;
- la conformité complète à une réglementation.

Certaines sources ont également été indisponibles, limitées ou accessibles uniquement après authentification.

Dans ces situations, aucune tentative de contournement n'a été réalisée.

2.3 Cadre légal et éthique

L'enquête a été conduite exclusivement à partir de sources accessibles publiquement et légalement.

Aucune tentative d'intrusion, d'exploitation de vulnérabilité, d'authentification non autorisée, de contournement de contrôle d'accès ou d'ingénierie sociale n'a été réalisée.

Les informations collectées ont été limitées à ce qui était nécessaire pour répondre aux objectifs de la mission.

2.4 OPSEC

Une attention particulière a été portée à la traçabilité et à la discrétion de la collecte.

Les recherches ont été réalisées de manière passive ou non intrusive.

Les résultats ont été enregistrés dans un journal chronologique et associés à des captures ou fichiers de preuve lorsque cela était pertinent.

Les données personnelles non nécessaires à l'analyse n'ont pas vocation à être reproduites dans le rapport final.

3. Méthodologie

3.1 Sources utilisées

Les recherches ont mobilisé plusieurs catégories de sources ouvertes :

- moteurs de recherche ;
- sites officiels ;
- registres publics ;
- réseaux professionnels accessibles publiquement ;
- données DNS ;
- API publiques ;
- sources spécialisées de cybersécurité ;
- outils de cartographie OSINT.

Les outils ont été sélectionnés en fonction de leur pertinence pour les pistes identifiées.

L'objectif n'était pas d'utiliser systématiquement l'ensemble des outils OSINT disponibles, mais de privilégier des sources légales, proportionnées et utiles à la validation des informations collectées.

3.2 Méthode de collecte

La collecte a été réalisée de manière progressive.

Une première phase a consisté à identifier la cible et son environnement professionnel.

Les recherches ont ensuite été élargies aux organisations associées, aux actifs numériques publics, aux données techniques et aux éventuels signaux de risque.

Chaque résultat pertinent a été documenté dans le fichier de sources et dans le journal chronologique de l'enquête.

3.3 Validation et corroboration

Une distinction a été maintenue entre :

- information confirmée ;
- information probable ;
- information à corroborer ;
- recherche non concluante ;
- source inaccessible.

Une information issue d'une seule source secondaire n'a pas été considérée comme définitivement confirmée lorsqu'aucune seconde source fiable ne permettait de la corroborer.

3.4 Niveaux de confiance

Le niveau de confiance accordé aux informations dépend notamment :

- de la nature de la source ;
- de son caractère officiel ou institutionnel ;
- de la possibilité de recouper l'information ;
- de sa date ;
- de sa précision ;
- de son accessibilité au moment de la collecte.

Les registres officiels et données techniques directement observables ont été considérés comme les sources les plus fiables.

Les résultats de moteurs de recherche et réseaux professionnels ont été utilisés comme indices lorsqu'ils ne pouvaient pas être corroborés.

4. Identification de la cible principale

4.1 Rémi Kinkel

Rémi Kinkel constitue la cible principale de substitution retenue pour l'exercice.

Les recherches ont permis d'identifier plusieurs éléments professionnels accessibles publiquement.

Une recherche dans l'Annuaire des Entreprises a notamment permis d'identifier une entreprise individuelle active au nom de Rémi Kinkel.

Le registre indique une activité principale relevant de l'enseignement supérieur, avec le code NAF 85.42Z.

L'entreprise a été créée en juin 2026 et apparaît comme immatriculée au Registre national des entreprises.

Afin de respecter le principe de minimisation, l'adresse personnelle ou précise du siège n'est pas reproduite dans ce rapport.

4.2 Fonctions professionnelles

Les sources publiques consultées font apparaître une activité professionnelle liée à la formation et aux systèmes informatiques.

Certains résultats indexés associent également Rémi Kinkel à des enseignements ou responsabilités dans le domaine des systèmes et réseaux.

Ces éléments sont cohérents entre eux mais leur niveau de confirmation varie selon la nature de la source.

4.3 Organisations liées

La Plateforme constitue l'organisation professionnelle la plus clairement associée à la cible dans les sources publiques consultées.

Un profil LinkedIn public correspondant vraisemblablement à la cible fait également apparaître une association avec AJC Formation.

Cette seconde relation n'a toutefois pas pu être corroborée de manière indépendante et n'est donc pas considérée comme un fait confirmé dans le cadre de l'analyse.

4.4 Présence numérique publique

La présence numérique publique de la cible apparaît relativement limitée.

Les recherches ont permis d'identifier plusieurs résultats professionnels, principalement liés à LinkedIn, à des sources institutionnelles indexées et aux registres officiels.

Les recherches effectuées via les API publiques de GitHub n'ont pas permis d'identifier de compte clairement attribuable à la cible selon les critères utilisés.

L'API GitLab interrogée a retourné un refus d'accès. Aucune tentative de contournement n'a été réalisée.

5. Analyse de La Plateforme

5.1 Identité juridique

Le site officiel et les mentions légales consultées présentent La Plateforme comme une association loi 1901 implantée à Marseille.

Un numéro SIRET est publiquement indiqué dans les mentions légales.

Ces informations constituent des éléments de contexte institutionnel utiles à l'identification de l'organisation étudiée.

5.2 Présence numérique

Le domaine principal identifié est :

laplateforme.io

Le site officiel constitue la principale présence numérique publique de l'organisation.

Un autre domaine distinct a également été identifié dans le cadre de l'enquête :

students-laplateforme.io

Ce domaine ne doit pas être confondu avec un sous-domaine de laplateforme.io.

5.3 Infrastructure publique

L'analyse passive du domaine laplateforme.io a permis d'identifier l'adresse IPv4 publique :

82.165.162.117

Cette information correspond uniquement à l'infrastructure publiquement observable au moment de l'enquête.

Elle ne permet pas à elle seule de déduire l'architecture interne du système d'information.

5.4 Exposition DNS et messagerie

Les enregistrements NS indiquent que la zone DNS publique est gérée par des serveurs de noms Gandi. Les enregistrements MX montrent que la messagerie entrante repose sur l'infrastructure Google.

L'analyse des enregistrements TXT révèle également une politique SPF autorisant plusieurs services tiers à émettre des courriels pour le domaine, notamment des infrastructures liées à Google, Mailchimp et HubSpot. Des

enregistrements de validation de domaine pour Google et Facebook ont également été observés.

Une politique DMARC est publiée pour le domaine :

v=DMARC1; p=none

La valeur p=none correspond à une politique de supervision : les messages échouant aux contrôles DMARC ne font pas l'objet, par cette politique, d'un rejet ou d'une mise en quarantaine automatique. Les rapports DMARC agrégés sont adressés à une infrastructure Brevo.

Aucun enregistrement CAA n'a été observé au niveau du domaine racine lors de la collecte. Aucune restriction explicite des autorités de certification n'est donc publiée par ce mécanisme.

La requête portant sur le CNAME de www.laplateforme.io n'a retourné aucun enregistrement CNAME. Cette observation ne signifie pas que le sous-domaine [www](http://www.laplateforme.io) est inexistant : il peut notamment être associé directement à un enregistrement A ou AAAA.

Ces observations ne constituent pas à elles seules des vulnérabilités. Elles permettent toutefois de cartographier l'exposition publique du domaine, d'identifier plusieurs prestataires externes et de faire apparaître des pistes de durcissement, notamment concernant la politique DMARC. **Preuves associées : OSINT-005 à OSINT-012. Preuves associées :**

- 03-preuves/dns/OSINT-005-dns-A.txt
- 03-preuves/dns/OSINT-006-dns-MX.txt
- 03-preuves/dns/OSINT-007-dns-NS.txt
- 03-preuves/dns/OSINT-008-dns-TXT.txt
- 03-preuves/dns/OSINT-009-dns-SOA.txt
- 03-preuves/dns/OSINT-010-dns-www-CNAME.txt
- 03-preuves/dns/OSINT-011-dns-DMARC.txt
- 03-preuves/dns/OSINT-012-dns-CAA.txt

5.5 Prestataires et dépendances techniques

L'analyse des enregistrements DNS et de messagerie met en évidence plusieurs prestataires externes.

Les serveurs MX observés sont associés aux services de messagerie Google.

Les serveurs de noms publics observés sont associés à Gandi.

L'enregistrement DMARC fait apparaître une adresse de reporting associée à Brevo.

D'autres services tiers apparaissent également dans les enregistrements TXT et SPF.

Ces dépendances ne constituent pas en elles-mêmes des vulnérabilités.

Elles représentent cependant des points à prendre en compte dans une due diligence, notamment concernant :

- la continuité de service ;
- la responsabilité contractuelle ;
- la gestion des accès ;
- la dépendance fournisseur ;
- les engagements de niveau de service.

6. Réputation et signaux faibles

Les recherches effectuées dans les sources publiques consultées n'ont pas permis d'identifier d'élément réputationnel grave ou de contentieux public directement attribuable à la cible.

Plusieurs liens professionnels ont été observés, notamment via des résultats de moteurs de recherche et des profils professionnels, mais certaines associations n'ont pas pu être corroborées par une deuxième source indépendante.

Les recherches menées dans le BODACC et le JOAFE n'ont donné aucun résultat pertinent au moment de la consultation.

L'absence de résultat ne constitue toutefois pas une preuve d'absence de risque ; elle signifie uniquement qu'aucun élément significatif n'a été identifié dans les sources et selon les critères de recherche utilisés.

7. Exposition cyber

7.1 Domaines et sous-domaines

L'analyse a permis d'identifier notamment les domaines :

- laplateforme.io
- students-laplateforme.io

Le second domaine constitue un domaine distinct et non un sous-domaine de laplateforme.io.

Ces actifs ont été intégrés à la cartographie de l'écosystème.

7.2 Vulnérabilités publiquement signalées

Une recherche dans les sources publiques spécialisées a permis d'identifier un rapport Open Bug Bounty concernant le sous-domaine students-laplateforme.io.

Le rapport OBB-4606788, publié le 4 juin 2026, décrit une vulnérabilité de type Improper Access Control (CWE-284).

Selon Open Bug Bounty, le signalement a été vérifié et l'opérateur du site a été notifié.

Les détails techniques ne sont pas publiquement accessibles dans le cadre de la procédure de divulgation coordonnée. Le statut public du rapport est indiqué comme "On Hold".

Cette observation constitue un signal de risque cyber pertinent dans le cadre de la due diligence. Elle ne permet toutefois pas d'affirmer que la vulnérabilité est toujours présente ou exploitable à la date de l'enquête.

Aucune tentative de reproduction ou d'exploitation de cette vulnérabilité n'a été réalisée.

Preuve associée :

03-preuves/cyber/OSINT-022-laplateforme-openbugbounty-access-control.png

8. Analyse de conformité

8.1 RGPD

L'enquête OSINT ne permet pas de conclure à la conformité ou à la non-conformité de l'organisation au RGPD.

Une telle évaluation nécessiterait notamment l'accès à des éléments internes tels que :

- le registre des traitements ;
- les politiques de conservation ;
- les contrats avec les sous-traitants ;
- les procédures relatives aux droits des personnes ;
- les mesures techniques et organisationnelles ;
- les éventuelles analyses d'impact.

L'analyse publique permet uniquement d'identifier certains points de vigilance pouvant justifier des vérifications complémentaires dans le cadre d'une acquisition.

8.2 NIS2

Le périmètre OSINT retenu ne permet pas de déterminer avec certitude l'assujettissement de l'organisation aux obligations issues de NIS2 ni d'évaluer son niveau réel de conformité.

La conformité NIS2 nécessiterait notamment une analyse de la taille de l'organisation, de son activité, de son éventuelle qualification réglementaire et de ses dispositifs internes de gestion des risques.

Aucune conclusion définitive n'est donc formulée sur ce point.

8.3 Limites de l'analyse de conformité

La présente analyse constitue uniquement une revue externe fondée sur des sources ouvertes.

Elle ne remplace ni un audit réglementaire ni un audit de conformité interne.

Dans le cadre d'une acquisition réelle, une phase de due diligence juridique, organisationnelle et technique complémentaire serait nécessaire.

9. Cartographie de l'écosystème

Une cartographie Maltego a été réalisée à partir des informations collectées et validées au cours de l'enquête.

Elle permet de représenter les principales relations identifiées entre la cible de substitution, son environnement professionnel, les actifs numériques publics, les prestataires techniques et les signaux de risque observés.

La cartographie fait notamment apparaître :

- Rémi Kinkel comme cible principale de l'investigation ;
- La Plateforme comme organisation professionnelle liée ;
- les domaines laplateforme.io et students-laplateforme.io ;
- l'adresse IPv4 publique 82.165.162.117 ;
- plusieurs dépendances techniques externes, notamment Gandi, Google et Brevo ;
- le rapport Open Bug Bounty OBB-4606788 ;
- la classification CWE-284 relative à un défaut de contrôle d'accès.

Certaines relations découvertes au cours de l'enquête n'ont pas été représentées comme des faits établis lorsque leur corroboration était insuffisante.

Cette cartographie constitue une représentation synthétique de l'écosystème observable depuis des sources ouvertes. Elle ne doit pas être assimilée à une cartographie exhaustive du système d'information interne.

Cartographie associée : 05-cartographie/cartographie-maltego-final.png

10. Analyse des risques

10.1 Méthode d'évaluation

Les risques identifiés ont été évalués selon deux critères :

- vraisemblance : note de 1 à 5 ;
- impact : note de 1 à 5.

Le score est calculé selon la formule :

Score = Vraisemblance × Impact

Les niveaux de criticité retenus sont :

- 1 à 4 : faible ;
- 5 à 9 : moyen ;
- 10 à 15 : élevé ;
- 16 à 25 : critique.

Cette cotation est fondée uniquement sur les informations publiquement accessibles au moment de l'enquête.

Elle ne remplace pas une analyse de risques interne disposant d'informations techniques, organisationnelles et contractuelles complètes.

10.2 Risques identifiés

R001 - Signalement public d'un défaut de contrôle d'accès

Un rapport Open Bug Bounty concernant students-laplateforme.io signale un défaut de type Improper Access Control, classé CWE-284.

Le signalement constitue un risque cyber significatif. L'enquête OSINT ne permet toutefois pas de déterminer si la faiblesse est encore présente ou si elle a été corrigée.

Criticité retenue : **élevée**.

R002 - Politique DMARC non restrictive

Le domaine laplateforme.io publie une politique DMARC configurée avec p=none.

Cette configuration permet la supervision des échecs d'authentification mais n'impose pas de rejet ou de mise en quarantaine automatique des messages non conformes.

Criticité retenue : **moyenne**.

R003 - Dépendances envers plusieurs prestataires externes

L'analyse de l'infrastructure publique a permis d'identifier plusieurs prestataires externes, notamment Google, Gandi et Brevo.

Ces dépendances ne constituent pas des vulnérabilités en elles-mêmes, mais elles introduisent des enjeux de gouvernance, de continuité de service, de responsabilité et de maîtrise du risque fournisseur.

Criticité retenue : **moyenne**.

R004 - Absence de politique CAA observée

Aucun enregistrement CAA n'a été observé au niveau du domaine racine lors de la collecte.

Cette absence constitue principalement une piste de durcissement concernant la délivrance de certificats TLS.

Criticité retenue : **faible**.

11. Recommandations

Au regard des éléments observés, plusieurs mesures sont recommandées avant ou immédiatement après une éventuelle acquisition.

Priorité élevée

- vérifier formellement l'état de correction du signalement OBB-4606788 concernant students-laplateforme.io ;
- réaliser une revue des mécanismes de contrôle d'accès des applications exposées ;
- effectuer un audit technique interne complémentaire afin de confirmer l'absence d'autres vulnérabilités non visibles depuis l'extérieur.

Priorité moyenne

- étudier une évolution progressive de la politique DMARC de p=none vers p=quarantine, puis éventuellement p=reject, après validation de la configuration SPF et DKIM ;
- documenter les dépendances aux prestataires externes, leurs responsabilités de sécurité, les SLA et les plans de continuité associés ;
- maintenir une surveillance régulière des domaines, sous-domaines, fuites et signalements de vulnérabilités.

Priorité faible

- étudier la mise en place d'enregistrements CAA afin de restreindre les autorités de certification autorisées à émettre des certificats pour le domaine.

12. Décision finale

Recommandation : GO CONDITIONNEL

Au regard des informations recueillies pendant l'enquête, aucun élément public identifié ne justifie à lui seul une recommandation de NO-GO.

Les recherches réalisées n'ont pas mis en évidence de compromission majeure confirmée, d'élément réputationnel grave ou de procédure publique susceptible de remettre directement en cause l'opération d'acquisition.

Toutefois, un signalement public relatif à un défaut de contrôle d'accès a été identifié sur students-laplateforme.io. L'état actuel de correction de cette faiblesse n'a pas pu être déterminé depuis les seules sources ouvertes.

Plusieurs pistes de durcissement ont également été relevées, notamment concernant la protection de la messagerie et la gestion des dépendances techniques externes.

En conséquence, la recommandation retenue est un :

GO CONDITIONNEL

La poursuite de l'opération est recommandée sous réserve :

- de confirmer la correction du signalement cyber identifié ;
- de réaliser un audit de sécurité interne complémentaire ;
- de vérifier la gouvernance et les responsabilités liées aux prestataires externes ;
- de mettre en œuvre les mesures de durcissement jugées pertinentes.

Cette recommandation est strictement limitée au périmètre OSINT et aux informations publiquement accessibles au moment de l'enquête.

13. Conclusion

Cette enquête de due diligence OSINT a permis de construire progressivement une vision de l'écosystème professionnel et numérique de la cible de substitution à partir de sources publiquement accessibles.

Les travaux ont notamment porté sur :

- l'identification professionnelle de Rémi Kinkel ;

- les organisations qui lui sont publiquement associées ;
- les registres officiels d'entreprises ;
- les sources institutionnelles et professionnelles ;
- l'infrastructure DNS et de messagerie de La Plateforme ;
- les dépendances techniques externes ;
- les annonces légales et associatives ;
- les profils et dépôts techniques publics ;
- les sources spécialisées de sécurité ;
- la cartographie des relations observées.

L'enquête a également démontré l'importance de distinguer les faits confirmés, les indices, les hypothèses et les informations non corroborées.

Plusieurs pistes initiales ont ainsi été volontairement écartées lorsqu'aucune source indépendante ne permettait de les confirmer.

L'OSINT présente par ailleurs des limites importantes : absence d'accès aux systèmes internes, informations parfois non indexées, contenus soumis à authentification, sources temporairement indisponibles et impossibilité de vérifier directement l'état actuel de certaines vulnérabilités.

Malgré ces limites, les éléments recueillis permettent d'identifier plusieurs risques et mesures de mitigation pertinentes.

La décision finale retenue est donc un **GO CONDITIONNEL**, sous réserve de vérifications techniques complémentaires et de la mise en œuvre des actions de sécurité recommandées.

Annexes techniques fournies séparément

Annexe A – Journal chronologique de l'enquête

Annexe B – Registre des sources

Annexe C – Registre des risques

Annexe D – Cartographie Maltego

Annexe E – Captures et preuves OSINT

Annexe F – Requêtes et dorks utilisés